

Implement List privileges

1. Create a new IAM user in your chosen cloud provider (AWS, Azure, or GCP) named 'foodieAppTester' and assign only the permissions needed to list storage buckets or containers, but not to create or delete them.

Hint: Use built-in roles like 'Storage Viewer' or create a custom policy with only 'list' actions.

ANS

1. Log in to the **AWS Management Console**.
2. Open **IAM** → **Users**.
3. Click **Create User**.
4. Enter the user name:
foodieAppTester
5. Do not attach any built-in policy.
6. Create a **custom policy** using the following JSON:
7. Attach this policy to **foodieAppTester**.

❖ **Result**

- ✓ The user can:
 - View the list of S3 buckets.
 - View bucket contents (if permitted).
- ✓ The user cannot:
 - Create buckets.
 - Delete buckets.
 - Upload files.
 - Delete files.

2. Audit the permissions of an existing IAM user or role in your cloud account and identify at least two permissions that are broader than necessary for a Zomato-style food delivery app backend (for example, full access to all services instead of just database and storage read/write).

ANS

Permission	Problem
AmazonS3FullAccess	Allows upload, download, delete, bucket creation, and bucket deletion. The application only needs access to one bucket.
AdministratorAccess	Grants full access to every AWS service. This is excessive for a backend application that only needs database and storage access.

- ✓ Both permissions are broader than necessary and violate the **Principle of Least Privilege**.

3. Modify the overly broad permissions you found in the previous task by editing the policy to restrict access only to the required services and actions (for example, allow only read/write to the food menu database and order storage, deny all other actions).

ANS

❖ Result

- Allowed:
 - Read and upload files in the **zomato-order-storage** bucket.
 - Read and update records in the **FoodMenu** DynamoDB table.
- Not Allowed:
 - Delete buckets.
 - Delete database tables.
 - Launch EC2 instances.
 - Access unrelated AWS services.

4. Use ChatGPT or Copilot to generate a least-privilege IAM policy JSON for a user who only needs to upload profile pictures to a 'user-profile-pics' storage bucket. Review the generated policy and apply it to a test user. Hint: Ask the AI tool to explain each permission in the policy so you understand what it allows.

ANS

Permission	Purpose
s3:PutObject	Allows uploading new profile pictures.
arn:aws:s3:::user-profile-pics/*	Restricts uploads to only the user-profile-pics bucket.

- This policy follows the **Least Privilege** principle because it only grants the minimum permission required to upload profile pictures. It does not allow downloading, deleting, or modifying bucket settings
5. Prepare a 3-minute presentation or a 1-page document showing your IAM user/role configurations, the before-and-after policy changes, and suggest one improvement to further tighten security for a Flipkart-style cloud backend.

ANS

❖ **Before**

- IAM users had broad permissions such as **AdministratorAccess** and **AmazonS3FullAccess**.
- Users could access unnecessary AWS services.
- The risk of accidental or malicious changes was high.

❖ **After**

- Permissions were restricted to only the required services.
- Users could access only specific S3 buckets and DynamoDB tables.
- Least-privilege policies reduced the attack surface.

❖ **Benefits**

- Improved security.
- Reduced risk of unauthorized access.
- Better compliance with AWS security best practices.
- Easier auditing and permission management.